



Weekly Cyber Threat Intelligence Report

Reporting window: 29 June - 6 July 2026

Australia - APAC - Global - Emerging Threats - IOCs to Add

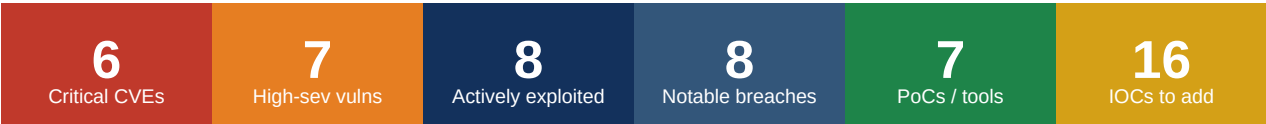
Prepared for: Jordan

Classification: TLP:CLEAR - cleared for public release

Source: CyberSec Vault automated intel sweep

PUBLIC

Executive Summary



This week was defined by **internet-facing enterprise apps and appliances being exploited within hours of disclosure**, an **AI/LLM attack surface moving from theory to mass exploitation**, and **supply-chain malware aimed squarely at developers and researchers**. Oracle E-Business Suite (CVE-2026-46817, CVSS 9.8) and a Langflow unauth RCE (CVE-2026-33017, exploited within 20 hours to drop cryptominers) led the exploited set, alongside SharePoint (CVE-2026-45659, CISA KEV), Cisco Unified CM SSRF-to-root (CVE-2026-20230), a CitrixBleed-class NetScaler overread (CVE-2026-8451) and Progress Kemp LoadMaster pre-auth root RCE (CVE-2026-8037). Adobe shipped seven max-severity ColdFusion/Campaign fixes and libssh2's OOB heap-write (CVE-2026-55200) gained public PoCs. On endpoints, 'Bad Epoll' (CVE-2026-46242) is a Linux UAF-to-root exploit that even escapes the Chrome sandbox. Supply-chain activity intensified: **DPRK/Lazarus** npm Rollup-polyfill packages and the **ChocoPoC** RAT hidden in trojanized GitHub PoCs both harvest developer secrets, while Microsoft pulled 119 steganographic 'StegoAd' Edge extensions (~2.6M installs). Espionage stayed visible with China-nexus **TinyRCT** hitting Southeast Asian government/energy targets. Regionally there were **no Australia-specific incidents**; APAC saw the 4.38M-customer Aflac Japan breach and a Blackfield ransom demand against Nidec via its Taiwan subsidiary. Notable breaches/takedowns: Medtronic (3.8M, ShinyHunters), the DHS HSIN compromise, and the Google/FBI dismantling of the 2M-device NetNut proxy. **Items are ordered verified-first, each with up to three independent references**; public PoCs/tool releases and indicators to add to blocklists/SIEM are called out in their own sections.

AUSTRALIA - SPECIFIC

Local orgs & data

No Australia items identified this reporting window.

APAC - SPECIFIC

Regional incidents & actors

TinyRCT - China-nexus APT CL-STA-1062 backdoors SE Asian govt & energy

HIGH

VERIFIED

APT

China

Backdoor

Palo Alto Unit 42 attributes a new C#/ .NET backdoor, TinyRCT, to Chinese-speaking cluster CL-STA-1062 (overlaps UAT-7237, seen hitting Taiwan in 2025). At least 10 government and energy organisations across Southeast Asia were breached Oct-Dec 2025. Delivery uses a 'chrome_setup.zip' with a legit signed EXE plus a rogue MyAppDomainManager.dll to trigger AppDomainManager injection; TinyRCT runs commands, exfiltrates files and screenshots, and beacons to 45.32.113[.]172 over HTTP with hard-coded AES-128-CBC (key ThisIsASecretKey87654321). Hunt for AppDomainManager side-loading and the C2 IP.

Refs: [unit42.paloaltonetworks.com](#) · [thehackernews.com](#) · [securityaffairs.com](#)

DPRK (Lazarus) npm packages impersonate Rollup polyfills, steal dev secrets

HIGH

VERIFIED

DPRK

npm

SupplyChain

Six North Korea-linked npm packages (e.g. rollup-packages-polyfill-core, rollup-runtime-polyfill-core) impersonated rollup-plugin-polyfill-node down to the metadata. At import time each ran a Base64-encoded npm install to stage a second package (swift-parse-stream, quirky-token), then fetched a JSON object from jsonkeeper[.]com and passed its 'model' field to eval() - so the payload never lived in the published files, evading static registry scanning. Capabilities: clipboard monitoring (tokens/wallet seeds), plus an interactive remote terminal and mouse/keyboard control on Windows. All six removed; same DPRK playbook as the 108-package April campaign (BeaverTail/OtterCookie).

Refs: [thehackernews.com](#) · [research.ifrog.com](#) · [techtimes.com](#)

Aflac Japan breach - 4.38M customers, premium-transfer bank data exfiltrated

HIGH

VERIFIED

Breach

Japan

Insurance

Aflac Japan found an unauthorised third party in its systems between 15-25 June 2026, exposing data on ~4.38 million customers - policy/coverage details, personal information, and premium-transfer bank account data for about 230,000 people (no credit-card data). Systems were suspended to contain the incident and Japan's FSA notified. Aflac says the incident is limited to Japan; US-business systems were not accessed. Among the largest APAC insurer breaches this year.

Refs: bleepingcomputer.com · japantimes.co.jp · securityaffairs.com

Blackfield ransomware demands \$2M from Nidec (Japan) via Taiwan subsidiary

MEDIUM

VERIFIED

Ransomware

Japan

Manufacturing

The Blackfield gang is demanding \$2M from Nidec Corporation (Japanese electronic-components maker, \$17.2B revenue, 40+ countries). Nidec's Taiwan subsidiary, Nidec Chaun Choung Technology, was hit on 22 June 2026, with server damage confirmed. Blackfield gave 15+ days to negotiate (offering to sell the data for \$400K, or a 1-day deadline extension for \$5K). Nidec is assessing production/shipping impact; the third extortion attempt on Nidec after 8Base and Everest. Continues heavy targeting of Japanese/Taiwanese manufacturing.

Refs: bleepingcomputer.com · cybermagazine.com · secnews.gr

Suspected DPRK BeaverTail sample - vscode-bootstrap.sh -> code-beautify[.]com

MEDIUM

UNVERIFIED

DPRK

Malware

Developer

A shared sample 'vscode-bootstrap.sh' (2 VirusTotal detections) beacons to code-beautify[.]com and is assessed as potentially DPRK BeaverTail-related (Contagious Interview / fake-interview developer lures associated with Lazarus, often paired with InvisibleFerret). Low-confidence, single-analyst attribution pending fuller analysis - retained unverified. Add the domain/filename to watchlists and treat unsolicited coding-task/interview lures as high-risk for developers.

Refs: x.com/LOPsec

GLOBAL - ACTIVELY EXPLOITED & CRITICAL CVEs

Patch now

CVE-2026-46817 - Oracle E-Business Suite (Payments) unauth takeover (CVSS 9.8), exploited

CRITICAL

VERIFIED

ERP

RCE

Exploited

Unauthenticated HTTP takeover of the Oracle Payments 'File Transmission' component (ibytransmit endpoint) - improper/missing authentication lets an attacker call an internal Java function to read files (e.g. /etc/passwd) and compromise Payments (CVSS 9.8). Affects EBS 12.2.3-12.2.15; patched in Oracle's late-May 2026 update. Exploitation recorded from ~27 June and a public PoC (PT-2026-44513) is out; 900+ EBS instances remain internet-exposed. Patch now, restrict EBS to internal networks, assume compromise.

PoC: Public - PoC/exploit published (PT-2026-44513); active exploitation since ~27 May - [mallory.ai](#)

Refs: [helpnetsecurity.com](#) · [bleepingcomputer.com](#) · [thehackernews.com](#)

CVE-2026-33017 - Langflow unauth RCE exploited within 20h (cryptomining, CISA)

CRITICAL

VERIFIED

AI/LLM

RCE

Exploited

Unauthenticated RCE in Langflow's public flow-build endpoint (POST /api/v1/build_public_tmp/{flow_id}/flow): an optional 'data' parameter is passed straight to exec() with no sandbox, so a single HTTP request runs arbitrary Python. Sysdig saw exploitation within 20 hours of the advisory - attackers built exploits from the write-up, dropped Monero miners, disabled security tools and spread over SSH; CISA sounded the alarm. Fixed in Langflow 1.9.0 (March 2026); all prior versions vulnerable. Update and keep Langflow behind authentication/VPN.

PoC: Active exploitation in the wild - Monero miners deployed within 20h of disclosure - [github.com](#)

Refs: [sysdig.com](#) · [csoonline.com](#) · [infosecurity-magazine.com](#)

Adobe patches 7 max-severity ColdFusion & Campaign flaws (multiple CVSS 10.0)

CRITICAL

VERIFIED

Adobe

RCE

Enterprise

Adobe shipped fixes for multiple maximum-severity flaws across ColdFusion and Campaign Classic. ColdFusion 2025 Update 10 / 2023 Update 21 resolve 11 defects incl. six CVSS 10.0 (CVE-2026-48276/-48277/-48281/-48316/-48282/-48283) enabling arbitrary code execution. CVE-2026-48286 (CVSS 10.0, incorrect authorization) hits on-prem Adobe Campaign Classic v7.4.3 build 9396 and earlier (fixed in build 9397). ColdFusion is aggressively targeted post-patch - prioritise internet-facing ColdFusion and on-prem ACC.

Refs: [bleepingcomputer.com](#) · [thehackernews.com](#) · [securityweek.com](#)

CVE-2026-8037 - Progress Kemp LoadMaster pre-auth root RCE (CVSS 9.8), PoC + exploited

CRITICAL

VERIFIED

Appliance

RCE

Exploited

An unauthenticated attacker can run root commands on Kemp LoadMaster via the /accessv2 endpoint when the API is enabled (CVSS 9.8 per ZDI). Root cause is escape_quotes() failing to null-terminate sanitised strings, giving an out-of-bounds heap read that chains to command execution. watchTower published a full exploit-chain write-up on 29 Jun and exploitation attempts began the same day. Patch to GA 7.2.63.2 / LTSF 7.2.54.18 and restrict management-API access.

PoC: Public - watchTower technical write-up & exploit chain; exploitation from 29 Jun - [thehackernews.com](#)

Refs: [thehackernews.com](#) · [cybersecuritynews.com](#) · [esentire.com](#)

CVE-2026-55200 - libssh2 out-of-bounds heap write (CVSS 9.2), public PoCs

CRITICAL

VERIFIED

Library

RCE

SupplyChain

An out-of-bounds heap write in libssh2's ssh2_transport_read() (transport-packet parsing) affects every version through 1.11.1. Because the flaw is client-side, a malicious or MITM SSH server can corrupt heap memory on a connecting client with no credentials and no interaction - a primitive that can reach RCE. libssh2 is embedded across curl, Git, PHP, backup/automation agents and firmware; multiple public PoCs are out. The cleanup challenge is finding bundled/static copies, not just the system package - inventory dependencies and patch.

PoC: Public - multiple PoCs on GitHub (0xBlackash/CVE-2026-55200 and others) - [github.com](#)

Refs: [x.com/TheHackersNews](#) · [x.com/IntCyberDigest](#) · [x.com/DarkWebInformer](#)

CVE-2026-45659 - Microsoft SharePoint on-prem RCE (CVSS 8.8), CISA KEV, exploited

HIGH

VERIFIED

SharePoint

RCE

Exploited

A deserialization-of-untrusted-data RCE in on-prem SharePoint (Subscription Edition, 2019, Enterprise 2016), patched May 2026 and rated 'less likely' by Microsoft, is now actively exploited - CISA added it to KEV on 1 Jul with a 4 Jul federal deadline. An authenticated user with only Site Member permissions can run code on the server; reports tie it to initial access followed by ransomware. Apply the May update and hunt for webshells / anomalous w3wp.exe child processes in ULS logs.

PoC: Active exploitation in the wild (initial access -> ransomware)

Refs: thehackernews.com · theregister.com · bleepingcomputer.com

CVE-2026-20230 - Cisco Unified CM SSRF-to-root (CVSS 8.6), exploited, CISA KEV

HIGH

VERIFIED

Cisco

SSRF

Exploited

An unauthenticated SSRF in Cisco Unified Communications Manager / SME (CVSS 8.6, rated Critical by Cisco) is exploited in the wild - Defused observed attacks over 21-22 June using file:// payloads to write files to the OS that can later escalate to root. Requires the WebDialer service (disabled by default). Cisco patched on 3 June; CISA's BOD 26-04 deadline was 28 June. Confirm the fix, disable WebDialer if unused, and hunt for attacker-written files on CUCM.

PoC: Public exploit code; active exploitation (file:// writes to disk)

Refs: bleepingcomputer.com · securityweek.com · cisco.com

CVE-2026-8451 - Citrix NetScaler pre-auth memory overread (CVSS 8.8), exploited

HIGH

VERIFIED

Citrix

InfoLeak

Exploited

A CitrixBleed-class pre-auth memory overread (CVSS 8.8): when NetScaler is configured as a SAML IdP, its XML parser fails to terminate unquoted attribute values followed by a newline, returning raw process memory in the NSC_TASS cookie - session tokens/secrets leak with one malformed request, no password needed. watchTower found it; Lupovis saw exploitation within 24h of disclosure (30 Jun). Patch to 14.1-72.61+/13.1-63.18+, rotate sessions/secrets, and hunt for anomalous NSC_TASS responses.

PoC: Active exploitation <24h after disclosure (Lupovis sensors) - labs.watchtower.com

Refs: thehackernews.com · cyberscoop.com · securityweek.com

BlueHammer - Microsoft Defender privilege-escalation flaw now exploited by ransomware

HIGH

UNVERIFIED

Windows

PrivEsc

Exploited

CISA confirmed ransomware gangs are exploiting a Microsoft Defender local privilege-escalation flaw dubbed 'BlueHammer' (previously abused as a zero-day). LPE via a security product is a high-value primitive (defence tampering + SYSTEM). Single-source at capture - retained unverified pending broader corroboration. Ensure Defender/platform updates addressing BlueHammer are applied and hunt for Defender tampering and privilege-escalation indicators per CISA KEV.

PoC: Active exploitation in the wild (CISA-confirmed)

Refs: bleepingcomputer.com

GLOBAL - OTHER NOTABLE VULNERABILITIES

High severity

CVE-2026-46242 'Bad Epoll' - Linux kernel eventpoll UAF to root (Android, Chrome-sandbox escapable)

HIGH

VERIFIED

Linux

LPE

PoC

A race-condition use-after-free in the Linux kernel epoll subsystem (ep_remove clears file->f_ep under f_lock but keeps using the freed file) lets an unprivileged local user reach root - and it can be triggered from inside Chrome's renderer sandbox, which blocks almost every other kernel bug. Affects servers, desktops and Android; a working exploit succeeds ~99% despite a 6-instruction window. Introduced by commit 58c9b016e128 (Apr 2023), fixed by a6dc643c6931 (Apr 2026); kernels v6.4+ without the backport are at risk. Patch distros/Android promptly.

PoC: Public - working exploit (github J-jaeyoung/bad-epoll); ~99% success - github.com

Refs: thehackernews.com · cybersecuritynews.com · techtimes.com

CVE-2026-39893 / -39955 / -39938 - Cacti pre-auth SQL injection (CVSS 9.8 each)

HIGH

VERIFIED

Monitoring

SQLi

PreAuth

Three critical pre-auth SQL injection flaws in Cacti (each CVSS 9.8). CVE-2026-39893 concatenates the 'rfilter' request variable into a RLIKE clause in graph_view.php with no sanitisation; on installs with guest graph-viewing enabled the endpoint is reachable unauthenticated (zero-click). Fixed in 1.2.31 (adds db_qstr_rlike() length-capping + metacharacter stripping). ~19.4K Cacti services were reported internet-exposed. Pre-auth SQLi on a monitoring server is high-value for pivoting - patch and disable guest viewing.

Refs: cyberpress.org · github.com · nvd.nist.gov

CVE-2026-8451 companion set - Citrix NetScaler six flaws (file read / DoS)

MEDIUM

VERIFIED

Citrix

DoS

FileRead

Alongside the exploited memory-overread (CVE-2026-8451), Citrix patched a batch of six NetScaler ADC/Gateway flaws spanning file read and denial-of-service. Even where not yet exploited, NetScaler remains a top ransomware on-ramp - apply the fixed builds (14.1-72.61+, 13.1-63.18+) across all appliances and review exposure of SAML IdP and management interfaces.

Refs: thehackernews.com · socradar.io · vulert.com

CVE-2026-24294 - NTLM reflection bypass to SYSTEM on Windows Server 2025 (public PoC)

HIGH

UNVERIFIED

Windows

NTLM

PoC

A researcher publicly disclosed an NTLM reflection-mitigation bypass with working PoC that yields SYSTEM on Windows Server 2025 - coercing/relaying authentication back to the same host defeats Microsoft's reflection protections. Single-source at capture (unverified). Apply the Microsoft fix for CVE-2026-24294, enforce SMB/LDAP signing and EPA, disable NTLM where feasible, and restrict PetitPotam-style coercion vectors.

PoC: Public - working PoC exploit yields SYSTEM

Refs: x.com/the_yellow_fall

Argo CD repo-server - unauthenticated code execution via Kustomize (no CVE, unpatched)

HIGH

UNVERIFIED

Kubernetes

RCE

Unpatched

Synacktiv showed that unauthenticated gRPC access to the Argo CD repo-server can execute commands: a crafted GenerateManifest request sets --helm-command to a script from an attacker-controlled Git repo, which runs when Kustomize executes. Post-exploitation, they read REDIS_PASSWORD from the environment, poisoned Argo CD's Redis cache, and had the attacker workload deployed on the next sync. No CVE and no patch at capture - the practical control is network isolation (verify NetworkPolicies for repo-server and Redis) and restricting repo-server gRPC exposure.

Refs: x.com/TheHackersNews

CVE-2026-13766 - DBIx::QuickORM (Perl) SQL injection (CVSS 9.8)

HIGH

UNVERIFIED

Perl

SQLi

DBIx::QuickORM fails to quote SQL identifiers, allowing SQL injection with no authentication and no interaction (reported CVSS 9.8); fixed in v0.000028. Applications on affected ORM versions are exploitable. Single-source vendor-feed report at capture (unverified) - upgrade immediately and review query construction for unquoted identifiers.

Refs: x.com/SecAlertsCo

CVE-2026-53309 - Linux kernel ocfs2/dlm off-by-one (severity disputed)

MEDIUM

UNVERIFIED

Linux

Kernel

OOB

An off-by-one in `dlm_match_regions()` in the `ocfs2/dlm` cluster code uses '`<=`' instead of '`<`', reading one entry past the `qr_regions` range. Vault capture cited CVSS 9.8 (network, unauth, full C/I/A) but public references describe a bounded kernel OOB read from a clustered-filesystem code path - the headline severity looks overstated and is retained unverified pending NVD scoring. Relevant mainly to hosts running `ocfs2` clusters; apply the kernel fix when your distro ships it.

Refs: nvd.nist.gov · cve.threatint.eu

GLOBAL - SOFTWARE SUPPLY CHAIN

Dev & researcher targeting

ChocoPoC - Python RAT hidden in trojanized GitHub PoC exploits (targets researchers)

HIGH

VERIFIED

PyPI

RAT

ResearcherTargeting

At least seven GitHub repos posing as PoCs for hot CVEs (FortiWeb, PAN-OS, Ivanti Sentry, Check Point VPN, Joomla, etc.) deliver ChocoPoC, a Python RAT - not in the exploit file but via a malicious PyPI dependency chain: 'frint' pulls 'skytext', which ships a compiled native extension that loads instead of a readable module. It steals saved passwords, cookies, autofill and history from Chrome/Brave/Edge/Firefox plus files, shell history and network config. Sekoia/YesWeHack found the malware and its servers still live as of 1 Jul. Never run untrusted PoCs on a primary host; audit requirements before running.

Refs: thehackernews.com · bleepingcomputer.com · sekoia.com

Trojanized Pyrogram forks on PyPI hijack Telegram bot servers

HIGH

UNVERIFIED

PyPI

SupplyChain

Telegram

A campaign active since ~November 2025 targets Python developers building Telegram bots with trojanised forks of Pyrogram (the popular MTPROTO library). The malicious forks add a backdoor enabling arbitrary file read on the bot host - creds, tokens and configs - giving attackers control of Telegram bot infrastructure. Single-source at capture (unverified). Install only the official Pyrogram, pin and verify source, audit bot servers for unexpected file-read behaviour, and rotate bot tokens.

Refs: bleepingcomputer.com

GLOBAL - PUBLIC PoCs & OFFENSIVE TOOL RELEASES

PoC / exploit code & tools

IPV6_FRAG_ESCAPE - unprivileged container / jail escape PoC

WATCH

UNVERIFIED

PoC

ContainerEscape

A public PoC by Massimiliano Oldani abuses IPv6 fragmentation handling to break out of an unprivileged container/jail (reported on CentOS 10 and Red Hat). Escape without root inside the container raises severity for multi-tenant and CI-runner isolation. Single-source (unverified) - validate against patched kernels and review container isolation on shared build infrastructure.

PoC: Public - PoC on GitHub ([sgkdev/ipv6_frag_escape](https://github.com/sgkdev/ipv6_frag_escape)); CentOS 10 / RHEL - x.com/nrathaus

Refs: x.com/nrathaus

Redis 8.8.0 'bidirectional' RCE - PoC teaser (pre-patch)

WATCH

UNVERIFIED

PoC

RCE

Redis

Researcher @gf_256 announced a Redis 8.8.0 bidirectional RCE, with PoC to be released after a fix ships; no technical detail public at capture. Track Redis advisories for an 8.8.x patch and plan a rapid upgrade. Never expose Redis to the internet - enforce auth, TLS and protected mode, and network-isolate. Single-source teaser (unverified).

PoC: Withheld - researcher states PoC to release after a patch

Refs: x.com/gf_256

Tradecraft Garden / Crystal Palace - free evasion tradecraft (Cobalt Strike creator)

INFO

UNVERIFIED

Tool

Evasion

RedTeam

The original creator of Cobalt Strike is publishing evasion tradecraft openly and for free: Tradecraft Garden separates evasion technique from capability, and Crystal Palace is the linker that composes those techniques independently of payload capability. Expect adoption by red teams and adversaries - detection engineers should study the primitives to build detections that don't rely on a single evasion-able signal. Single-source (unverified).

Refs: x.com/cr3ghost

heavener - EDR emulation engine (extracts vendor detection logic)

INFO

UNVERIFIED

Tool

EDR

RedTeam

A modular engine that runs real vendor detection logic - ML models, YARA rules and behaviour scripts reverse-engineered from SentinelOne, Cortex-XDR, CrowdStrike and Sophos - against live/replayed Windows telemetry locally, so operators can test payloads against extracted detection logic offline before engagements. Useful for both red teams and detection tuning. Single-source (unverified).

Refs: x.com/MalwareBibleJP

SpotifyC2 - C2 via Spotify playlists + Telegram output

INFO

UNVERIFIED

Tool

C2

LOTS

A research C2 framework that retrieves commands from Spotify playlists and returns output via Telegram - illustrating living-off-trusted-services C2 where traffic to Spotify/Telegram blends with normal usage and evades naive egress filtering. Defenders should baseline and inspect API traffic to trusted SaaS. Single-source release (unverified).

Refs: github.com · x.com/0x534c

CredSpy - unauthenticated Microsoft account auth-method enumeration

INFO

UNVERIFIED

Tool

Recon

Identity

An open-source tool for unauthenticated enumeration of Microsoft account authentication methods (passkey, certificate, passwordless push) - useful to profile an org's MFA posture and spot accounts without phishing-resistant auth. Defensive takeaway: adopt phishing-resistant MFA broadly so enumeration yields no soft targets. Single-source release (unverified).

Refs: github.com · x.com/RedByte1337

KeyHunter - Rust leaked-API-key finder with live-key verification

INFO

UNVERIFIED

Tool

Recon

Secrets

A fast Rust tool that finds leaked API keys across public GitHub repos for 45+ providers and verifies which exposed secrets are still active. Doubles as a defensive secret-scanning aid - run against your own org's public repos and rotate any live keys. Single-source release (unverified).

Refs: github.com · x.com/DarkWebInformer

GLOBAL - MALWARE & CAMPAIGNS**StegoAd - Microsoft removes 119 malicious Edge extensions (steganographic payloads, ~2.6M installs)**

HIGH

VERIFIED

BrowserExt

Infostealer

AdFraud

Microsoft removed 119 Edge extensions (up to ~2.6M installs, one actor active since 2021) that hid executable payloads inside PNG/WebP/WOFF2 files via steganography, then stole credentials and ran ad fraud. Posing as ad blockers, VPNs, translators and downloaders, they used delayed activation, DevTools detection, server-side validation and a 10% execution gate to evade review. Microsoft suspended the 90+ developer accounts. Audit installed Edge extensions, enforce extension allow-listing, and hunt for extension-driven credential exfil.

Refs: thehackernews.com · techradar.com · techtimes.com

Kongtuke ClickFix campaign sideloads Havoc C2 via signed WinWrapIDE

HIGH

UNVERIFIED

ClickFix

C2

Infostealer

Unit 42 reports a Kongtuke ClickFix campaign that DLL-sideloads Havoc C2 using a legitimately signed WinWrapIDE binary, then runs a memory-only infostealer with window cloaking, sandbox sleep and native callback evasion. Single-source at capture (unverified). Alert on ClickFix patterns (clipboard-to-Run/PowerShell), baseline signed-binary child processes for WinWrapIDE sideloads, and favour EDR memory scanning over file scanning for the disk-less stealer.

Refs: x.com/Unit42_Intel

Avalon -> CrownX ransomware via PDF-themed .LNK chain

HIGH

UNVERIFIED

Ransomware

LOLBin

Evasion

A ransomware chain (Avalon deploying CrownX): PDF-themed .LNK -> Proton Drive-hosted ISO -> MSBuild execution -> ETW tampering -> HTTPS payload delivery, culminating in the CrownX ransom note after credential theft and C2. Living-off-the-land via MSBuild plus ETW tampering blinds EDR telemetry, and legitimate cloud (Proton Drive) is used for staging. Single-source (unverified). Block/monitor .LNK-to-ISO execution, MSBuild abuse and ETW tamper indicators.

Refs: x.com/TheHackersNews

FortiBleed credential-theft campaign linked to INC & Lynx ransomware

HIGH

UNVERIFIED

CredTheft

Fortinet

Ransomware

The large-scale FortiBleed campaign harvesting Fortinet credentials has been tied to the INC and Lynx ransomware operations - stolen VPN creds feeding downstream ransomware initial access. Single-source at capture (unverified). Rotate Fortinet/VPN credentials, enforce MFA on all remote-access appliances, and review VPN auth logs for credential-stuffing and INC/Lynx precursor activity.

Refs: bleepingcomputer.com

EtherRAT - Teams 'System Administrator' phishing with Ethereum smart-contract C2

MEDIUM

UNVERIFIED

RAT

Teams

BlockchainC2

Unit 42 details a campaign where an actor impersonates a 'System Administrator' over Microsoft Teams to seize remote control and deploy EtherRAT via malicious MSI/PowerShell; the RAT's C2 addressing is hidden in an Ethereum smart contract (takedown-resistant dead-drop resolver). Single-source (unverified). Restrict external Teams messaging/screen-control, alert on MSI/PowerShell chains from Teams, and monitor for blockchain-RPC lookups from endpoints.

Refs: x.com/Unit42_Intel

N4D Mesh Controller - MCP-exploiting, AI-aware botnet

MEDIUM

UNVERIFIED

Botnet

AI/MCP

Automation

Described by Germán Fernández (amplified by @malwrhunterteam) as more than a botnet: an active campaign combining generic MCP (Model Context Protocol) exploitation, automated multi-step attack-chain planning, direct AI/LLM-infrastructure targeting and increasingly defence-aware behaviour. Signals botnets integrating agentic/LLM tooling into attack orchestration. Two-source X reporting (unverified) - watch for anomalous MCP endpoint access and outbound LLM-API calls from unexpected hosts.

Refs: x.com/1ZRR4H

GLOBAL - NOTABLE BREACHES

Medtronic - 3.8M notified after ShinyHunters breach (health data)

HIGH

VERIFIED

Healthcare

ShinyHunters

PII

Medtronic is notifying 3,834,294 people after an April 2026 intrusion (unauthorised access to corporate IT systems 13-19 April; notifications began 29 June). Exposed data may include names, contact details, dates of birth, Social Security numbers and health information. ShinyHunters claims 9M+ records; Medtronic says no products, patient safety or care delivery were affected and is offering 24-month credit/identity monitoring. Part of the wider ShinyHunters extortion wave.

Refs: bleepingcomputer.com · securityweek.com · hipaajournal.com

DHS confirms breach of HSIN information-sharing platform (World Cup security planning)

HIGH

VERIFIED

Government

US

IntelSharing

DHS confirmed (disclosed 1 Jul) that an unknown actor accessed the Homeland Security Information Network - a sensitive-but-unclassified platform for federal/state/local/tribal/international/private partners - between late May and early June, targeting both HSIN servers and a SharePoint collaboration system. It drew lawmaker concern given HSIN's role coordinating World Cup 2026 security; DHS says classified systems were not affected and has not attributed the intrusion.

Refs: bleepingcomputer.com · nextgov.com · cybersecuritynews.com

Google/FBI/Lumen dismantle NetNut ('Papa') residential proxy - 2M devices

HIGH

VERIFIED

Takedown

Botnet

Proxy

Google, with the FBI, Lumen and partners, disrupted the NetNut residential proxy network (tracked as 'Papa'), which co-opted 2M+ consumer devices - many budget smart TVs/streaming boxes shipping with proxy code, others via apps bundling a hidden SDK. In one June week GTIG saw 316 distinct threat clusters (cybercrime and espionage) using NetNut exit nodes for password spraying and origin masking. Google disabled the C2 accounts/services; NetNut's site now shows an FBI/IRS-CI seizure notice.

Refs: thehackernews.com · krebsonsecurity.com · bleepingcomputer.com

Huntress LSHIY password-spray - 81M login attempts, 78 Microsoft accounts compromised

HIGH

VERIFIED

PasswordSpray

M365

Identity

Huntress reports an ongoing password-spray campaign ('LSHIY') that made 81M+ login attempts against customer accounts between 12-26 June and compromised at least 78 Microsoft/Entra accounts - the volume indicates automated distributed infrastructure, and successful takeover risks BEC, lateral movement and data theft. Enforce phishing-resistant MFA on all Microsoft/Entra accounts, alert on spray patterns and impossible-travel, and review conditional-access policies.

Refs: x.com/LindseyOD123 · bleepingcomputer.com

Kubota North America - month-long access, HR data for employees & dependents

MEDIUM

VERIFIED

Manufacturing

US

PII

Kubota North America disclosed attackers had access to network systems for over a month (16 March-20 April), reaching HR files with data on employees and dependents. Potentially exposed: names, Social Security numbers, dates of birth, taxpayer IDs, government ID numbers, bank account and corporate payment-card information, and benefits/claims data. Notifications began 30 June; no group had claimed responsibility as of 1 July and no operational disruption was reported. Notable dwell time indicating delayed detection.

Refs: bleepingcomputer.com · aqdaily.com · securityboulevard.com

Nissan Americas - employee data breach via Oracle PeopleSoft 0-day

MEDIUM

UNVERIFIED

Breach

PeopleSoft

PII

Nissan Americas confirmed a breach affecting current and former employees across four countries after actors exploited the critical Oracle PeopleSoft zero-day (CVE-2026-35273) - the same ShinyHunters data-theft campaign tracked previously. Single-source at capture (unverified). A downstream victim of the PeopleSoft 0-day wave; employee PII exposure raises phishing/identity-theft risk for staff. Treat internet-exposed PeopleSoft as compromised and rotate secrets.

Refs: x.com/The_Cyber_News

Netim (France) - domain registrar data, source code & customer records for sale**MEDIUM****UNVERIFIED****DataSale****Registrar****DarkWeb**

A threat actor is advertising a claimed one-time sale of comprehensive Netim.com data (France-based ICANN-accredited registrar/host): customer records (names, addresses, phone numbers, partially anonymised emails, password hashes), an internal database dump, source-code repositories, and production infrastructure/financial details, priced in crypto via escrow. Two-source dark-web reporting (unverified) - listing only. Registrar compromise carries downstream DNS/hijack risk for hosted domains; monitor for anomalous DNS changes.

Refs: x.com/DarkWebInformer · x.com/DailyDarkWeb

HMG Hospital (Saudi Arabia) - 452,578 patient records advertised for sale**MEDIUM****UNVERIFIED****Healthcare****DataSale****DarkWeb**

A forum actor claims to be selling 452,578 patient records tied to HMG Hospital (described as a major Saudi Arabian hospital), centred on patient-level medical and billing data. Single-source, listing only (unverified). If validated, high-sensitivity health/PII exposure with regulatory and fraud implications - monitor for corroborating leak-site activity and any confirmation from the organisation.

Refs: x.com/DarkWebInformer

INDICATORS OF COMPROMISE (IOCs) TO ADD

Blocklist / SIEM

Indicator	Type	Context	Reference
CVE-2026-46817	CVE	Oracle EBS Payments unauth takeover (9.8); exploited + PoC	helpnetsecurity.com
CVE-2026-33017	CVE	Langflow unauth RCE; exploited in 20h (cryptomining) - fix 1.9.0	sysdig.com
CVE-2026-45659	CVE	SharePoint on-prem RCE (8.8); CISA KEV, exploited	thehackernews.com
CVE-2026-20230	CVE	Cisco Unified CM SSRF->root (8.6); KEV, exploit code public	bleepingcomputer.com
CVE-2026-8451	CVE	Citrix NetScaler pre-auth memory overread (8.8); exploited	cyberscoop.com
CVE-2026-8037	CVE	Kemp LoadMaster pre-auth root RCE (9.8); PoC - fix 7.2.63.2	thehackernews.com
CVE-2026-55200	CVE	libssh2 OOB heap write (9.2) through 1.11.1; public PoCs	github.com
CVE-2026-46242	CVE	'Bad Epoll' Linux kernel UAF->root; PoC, Chrome-sandbox escapable	thehackernews.com
CVE-2026-39893 / -39955 / -39938	CVE	Cacti pre-auth SQLi (9.8 each); fix 1.2.31	github.com
CVE-2026-48286	CVE	Adobe Campaign Classic on-prem code exec (10.0); fix build 9397	bleepingcomputer.com
45.32.113[.]172	IP (C2)	TinyRCT .NET backdoor C2 (CL-STA-1062, SE Asia)	unit42.paloaltonetworks.com
code-beautify[.]com	Domain (C2)	Suspected DPRK BeaverTail (vscode-bootstrap.sh)	x.com/LOPsec
jsonkeeper[.]com	Domain (loader)	DPRK npm Rollup-polyfill payload staging (eval)	thehackernews.com
rollup-packages-polyfill-core / rollup-runtime-polyfill-core	npm packages	DPRK malicious npm (secret theft); removed	research.jfrog.com
frint / skytext	PyPI packages	ChocoPoC RAT dependency chain (researcher targeting)	sekoia.com
176.125.243[.]14:8080	IP:port (open dir)	Tax-themed lure (1040.pdf / Adobe_Tax_Notice.pdf + b.ps1)	x.com/malwrhuntearteam

Defanged indicators - re-fang before importing. Verify against your environment before blocking.

TRENDS & EMERGING THREATS TO WATCH

Forward look

HIGH

Enterprise apps & appliances exploited within hours of disclosure

Why it matters: Oracle EBS, Langflow (20h to cryptomining), SharePoint, Cisco Unified CM, Citrix NetScaler and Kemp LoadMaster were all exploited this week - several before or immediately after PoCs landed. The window between disclosure and mass exploitation is now measured in hours.

Watch for: unpatched internet-facing ERP/collaboration/ADC/load-balancer/AI-gateway software; CISA KEV additions; webshells and attacker-written files on appliances; anomalous management-plane access.

HIGH

AI/LLM infrastructure is now a mass-exploited attack surface

Why it matters: Langflow's unauth RCE was weaponised for cryptomining within a day, iOS AI apps leaked replayable LLM keys, and the N4D botnet exploits MCP and targets AI infrastructure directly. AI gateways, dev platforms and agents are routinely attacked, not just researched.

Watch for: exposed LLM gateways/proxies (LiteLLM, Langflow); API-key sprawl on AI hosts; MCP endpoint access from unexpected sources; agents acting on untrusted content without human-in-the-loop.

HIGH

Supply-chain malware targeting developers & vulnerability researchers

Why it matters: DPRK/Lazarus npm Rollup-polyfill packages, the ChocoPoC RAT in trojanized GitHub PoCs, trojanized Pyrogram PyPI forks and 119 StegoAd Edge extensions all execute at install/import and steal developer, browser and cloud secrets - with researchers specifically lured via fake exploits.

Watch for: dependency installs that execute on import; remote payloads pulled via eval/jsonkeeper; native extensions loading instead of readable modules; running untrusted PoCs on primary hosts; new maintainer tokens.

MED

DPRK & China-nexus espionage and developer-targeting in APAC

Why it matters: China-nexus CL-STA-1062 deployed the TinyRCT backdoor against Southeast Asian government and energy targets, while DPRK ran npm and BeaverTail developer lures. Patient, custom-tooled access continues to focus on the region and on developers.

Watch for: AppDomainManager side-loading; the TinyRCT C2 (45.32.113[.]172); fake coding-task/interview lures; DPRK npm/PyPI packages in recent installs; long-dwell access on edge and dev systems.

MED

ClickFix & fake-verification social engineering plus OAuth consent theft

Why it matters: Kongtuke ClickFix sideloaded Havoc C2, fake Google/Cloudflare 'verification' pages spread multiple malware families, and a verified X ad plus ConsentFix hijacked Microsoft 365 accounts via OAuth - all bypassing MFA by abusing user trust and tokens.

Watch for: clipboard-to-Run/PowerShell patterns; fake CAPTCHA/verification prompts asking users to paste commands; new third-party OAuth app grants in Entra ID; device-code authentications from unexpected users.

MED

Memory-disclosure & credential theft feeding ransomware

Why it matters: The CitrixBleed-class NetScaler overread (CVE-2026-8451), the FortiBleed campaign feeding INC/Lynx, and an 81M-attempt Microsoft password spray all convert leaked/sprayed credentials into ransomware initial access on the network edge.

Watch for: anomalous NSC_TASS responses from NetScaler; Fortinet/VPN credential reuse; high-volume login/spray patterns; impossible-travel sign-ins; absence of phishing-resistant MFA.

PRIORITY ACTIONS THIS WEEK

Area	Action
Patch now	Oracle EBS (CVE-2026-46817); Langflow -> 1.9.0 (CVE-2026-33017); SharePoint May update (CVE-2026-45659); Cisco Unified CM (CVE-2026-20230); Citrix NetScaler -> 14.1-72.61/13.1-63.18 (CVE-2026-8451); Kemp LoadMaster -> 7.2.63.2 (CVE-2026-8037); Adobe ColdFusion/Campaign; Cacti -> 1.2.31 (CVE-2026-39893 set); libssh2 (CVE-2026-55200); Linux kernel 'Bad Epoll' (CVE-2026-46242); Microsoft Defender (BlueHammer).
Block IOCs	Add the IOC-table indicators (CVE IDs, TinyRCT C2 45.32.113[.]172, code-beautify[.]com, jsonkeeper[.]com, DPRK npm / ChocoPoC PyPI package names, tax-lure open dir) to firewall/EDR/SIEM blocklists and alert on the listed CVEs.
Assume compromise	Treat internet-exposed Oracle EBS/PeopleSoft, SharePoint, Cisco Unified CM and Citrix NetScaler as potentially compromised - hunt for webshells, attacker-written files and leaked session tokens; rotate appliance secrets and SAML material.
Supply chain	Never run untrusted PoCs on primary hosts; audit dependencies before install; pin + hash-verify; watch for import-time execution and eval/remote-fetch payloads; rebuild recent npm/PyPI installs; rotate developer, browser, cloud, SSH and CI secrets.
AI / LLM	Put Langflow and LLM gateways behind authentication/VPN and rotate reachable API keys; inventory exposed AI dev platforms; restrict MCP endpoints; require human-in-the-loop for agent actions on untrusted content.
Identity	Enforce phishing-resistant MFA (FIDO2/passkeys) on Microsoft/Entra; restrict user OAuth app consent and alert on new third-party grants; disable device-code flow where unneeded; monitor for spray/impossible-travel.
Endpoints & people	Patch 'Bad Epoll' on Linux/Android and Defender (BlueHammer) on Windows; brief staff on ClickFix/fake-verification and Teams IT-impersonation lures; audit browser extensions and enforce allow-listing.